Spencer Taylor

Spring 2025

Case Study 2 - Target (2013)

Introduction

The Target breach is often treated like a technical story, but the bigger lesson is how security information gets handled inside a company. Target had security tools and monitoring, but attackers entered through a third-party vendor and the incident grew into a large theft of customer data. This case shows that detecting risk is not the same as acting on it. When to escalate is unclear, when vendor access is treated as just routine, and when internal systems are not well separated, a breach can spread faster than the organization responds. In this analysis, I focus on leadership and governance, third-party vendor risk, ethics and communication, and how segmentation or a Zero Trust approach could have reduced the impact.

Problem statement

Target had warnings and security tools, but the response was not fast or coordinated enough. Vendor access and weak network separation were treated like routine IT tasks, not a major business risk. Once attackers got in through a vendor, the gaps helped the breach spread into systems that were tied to customer payments and that had personal data.

SWOT Analysis

Strengths:

- Target is huge and has money, staff, and existing security tools, so once they decide to fix something they can actually do it.
- Brand recognition helps them recover, even after trust takes a hit.

Weaknesses:

- Vendor access was a weak point and it seems like it wasn't locked down enough for the actual risk it has.
- Network separation wasn't strong enough to keep a vendor issue from spreading.
- The response process wasn't tight, so warnings didn't quickly turn into action.

Opportunities:

- Tighten the vendor access rules and make it harder for any vendor account to reach anything sensitive.
- Improve segmentation and make sure it's tested.
- Rebuild trust with better communication and better customer support during incidents.

Threats:

- Customers can leave pretty easily, so trust loss can turn into lost sales.
- Legal pressure and regulatory attention can drag on for a long time.
- Banks/card networks can push stricter requirements and make things more expensive.

Porter's Five Forces (after the breach)

Buyer power: Buyer power goes up because customers have a lot of choices and now trust is part of the decision. If people feel unsafe, switching stores is easy.

Rivalry: Rivalry gets worse because competitors can use security and trust as a selling point, even if it's partly just perception. Target has to work harder to prove they fixed things.

Threat of new entrants: For physical retail, new entrants are still limited, but online-first companies have an easier time. Also, newer companies can build more modern security from the start, which can be an advantage.

Threat of substitutes: Substitutes get more attractive because customers can switch to other retailers or shop online with basically no effort. After a breach, that switch feels even easier.

Supplier power: Supplier power increases in the payment ecosystem. Banks and card networks can demand tighter controls and faster changes because they don't want to eat fraud costs or deal with repeated incidents.

1) Leadership failure and governance improvements

One problem was that warnings didn't lead to quick action. Alerts only help if there's a clear rule for when leadership has to step in. During the holidays, retail teams try hard to avoid downtime, and that can lead to containment getting delayed unless the rules are already decided in advance. (Nelson et al., 2025)

Leadership and organization structures that could have improved response time include:

- Clear escalation rules for payment-related alerts (what gets escalated, to who, and how fast).

- One accountable leader of security with the authority to coordinate a response across IT, store operations, and vendors.
- Leadership and the board need to pay closer attention. They should look at a few basic measures that show whether security controls are working, like response time on serious alerts, vendor rule compliance, and segmentation test results.

If customer trust and smooth payments matter to the business, then security of information relating to both can't be handled like normal IT maintenance. Leadership has to pay attention, and it needs to be clear who makes the fast decisions when something serious happens.

2) Third-party vendor risk and prevention steps

The breach started through a vendor, which highlights how third parties expand a company's attack surface. Vendor management cannot be only policy documents and annual reviews. It needs technical controls that limit what vendor accounts can access and what happens if those credentials are stolen.

Preventative measures that could have reduced or prevented the breach include:

- requiring MFA for vendor remote access (PCI Security Standards Council)
- limiting vendor access to least privilege
- isolating vendor access so it cannot reach payment-related systems

- monitoring vendor accounts for unusual behavior (something similar to weird access times or systems that do not match the vendor's role)

The main goal is containment. Even if a vendor is compromised, the attacker should not be able to move into sensitive systems.

3) Ethical obligations and communication

Retailers have an ethical responsibility to protect customer data because customers have basically no choice on providing it during transactions. After a breach, they also have a responsibility to reduce harm through clear and practical communication. Public perception relies on if customers feel informed and supported. If messages change repeatedly or customers can't get help, trust can/will drop fast, even if the company is working behind the scenes. A stronger approach is early acknowledgement, a clear set of “what to do next” guidance, and regular updates with consistent timing.

4) Zero Trust and segmentation, plus legacy challenges

A Zero Trust approach assumes credentials will eventually be stolen, including vendor credentials. The point is to limit access by default and reduce how far an attacker can move once inside (Rose et al., 2020). Even without a full Zero Trust rollout, stronger network segmentation would have limited the breach by separating vendor access and store networks from payment environments.

Upgrades are also harder in retail than they appear. Systems are large, distributed, and tied to daily store operations. Downtime is expensive and visible to customers, and multiple teams often share ownership (stores, corporate IT, security, vendors). That reality makes clear governance and phased upgrades important.

Stakeholders

Key stakeholders include customers (fraud risk and trust), Target leadership and the board (oversight and reputation), IT and security teams (response workload and authority), banks/card networks (fraud and card replacement costs), vendors (higher access requirements), and regulators/the public (consumer protection expectations).

Alternatives considered

Alternative A: Minimal changes with a PR focus. Cheaper short-term, but it does not address the structural weaknesses that actually allowed the breach to spread.

Alternative B: Targeted control and governance fixes first. This focuses on vendor access, network separation, and escalation rules, and it's realistic to put in place quickly.

Alternative C: An immediate full Zero Trust overhaul. Strong long-term direction, but expensive and disruptive to do all at once. Better as a phased roadmap after immediate gaps are closed.

Recommendation and course of action

I recommend Alternative B now, paired with a phased Zero Trust roadmap. Immediate actions should enhance and tighten control on vendor access (Multi-Factor Authentication and least privilege), separate vendor access from payment systems, and define escalation rules so high-risk alerts trigger a set of rapid containment decisions. Over the next few months, Target should test segmentation in practice, update the incident response plan so that authority is clear during peak periods, and provide company leadership with a small set of security indicators tied to business risk. Long term, Target should move toward Zero Trust principles in phases across identity, network boundaries, and monitoring.

Conclusion

The Target breach was not just a technical failure. It was a governance and containment failure where vendor exposure and weak network separation allowed what should've been just a local compromise to become a major customer data incident. The best response is to Tighten the basics (vendor access, network separation, and escalation rules) and make it clear who can act fast when a serious threat shows up.

References

Nelson, Alex, et al. “Incident Response Recommendations and Considerations for Cybersecurity Risk Management”: *NIST*, Apr. 2025, nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r3.pdf.

PCI Security Standards Council. *PCI DSS V4.x Quick Reference Guide*. Jan. 2025.

Rose, Scott, et al. “Zero Trust Architecture.” *Csrc.nist.gov*, 11 Aug. 2020, csrc.nist.gov/pubs/sp/800/207/final.